DOSSIER SÉCURITÉ

Vos données restent chez vous. Voici comment, point par point.

Une IA installée sur site, aussi appelée IA souveraine ou IA on-premise, ne vaut que si chaque mesure est vérifiable. Cette page est écrite pour le responsable informatique, le commandant ou l'associé qui doit répondre de la sécurité. Ce qui est fixé à l'installation est dit comme tel, et ce qui n'est pas encore fait aussi.

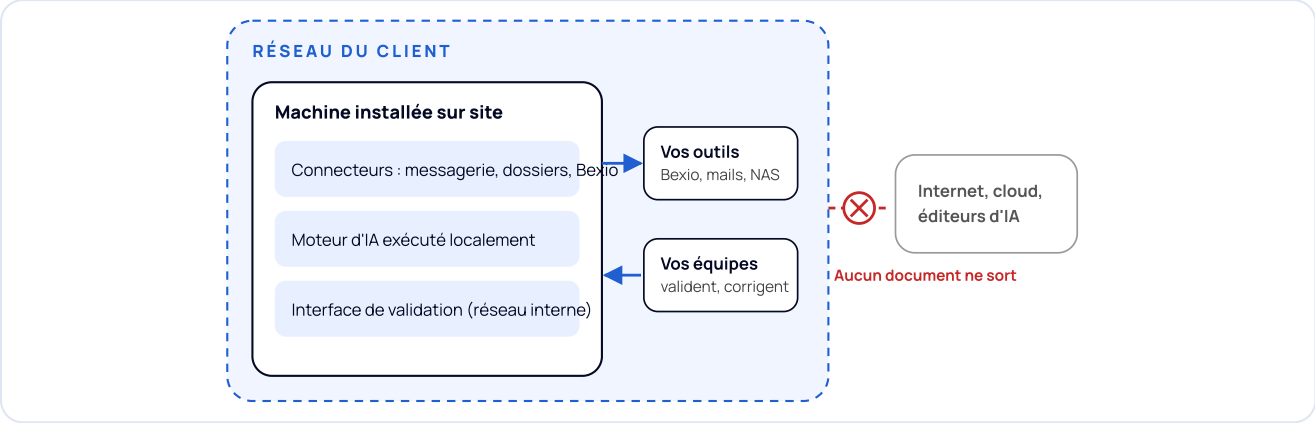
Résumé pour la direction

1. **Où tournent les données.** Sur une machine installée chez vous, sur votre réseau, sans appel vers un service externe pendant le traitement.
2. **Architecture.** Trois briques sur une seule machine : les connecteurs vers vos outils, le moteur d'IA, et l'interface de validation.
3. **Chiffrement.** Chiffrement du disque au repos et des échanges en transit sur votre réseau.
4. **Contrôle des accès et journalisation.** Vous décidez qui accède au système ; chaque action est journalisée chez vous.
5. **Sauvegardes.** Les sauvegardes sont faites sur vos supports, selon votre politique.
6. **Mises à jour.** Planifiées avec vous, appliquées sur place ou par un accès que vous ouvrez le temps de l'intervention.
7. **En fin de contrat.** La machine et les données restent chez vous. Le système continue de fonctionner.
8. **nLPD et secret professionnel.** Conçu pour respecter la nLPD : les données ne quittent pas vos murs et ne sont transmises à aucun tiers.
9. **Test d'intrusion.** Aucun test d'intrusion indépendant n'a encore été réalisé ; il sera documenté ici quand il aura lieu.

Ce dossier n'est pas un avis juridique. Les points marqués en jaune sont en cours de confirmation et seront remplacés dans la version suivante, datée et numérotée.

PAGE 2

Architecture et flux de données



Où tournent les données

Sur une machine installée chez vous, sur votre réseau, sans appel vers un service externe pendant le traitement.

- Le système est installé sur une machine dédiée dans vos locaux, fournie avec lui : un Mac mini Apple (puce M4 Pro, 64 Go de mémoire unifiée), de la taille d'un livre.
- Pendant le traitement d'un document, aucune requête ne part vers un service externe : ni vers un éditeur de modèle d'IA, ni vers LX Studio.
- Les documents traités, les résultats et les journaux restent sur le disque de cette machine.
- Les connecteurs vers vos outils (Bexio, messagerie, dossiers) parlent à ces outils depuis votre réseau, avec vos comptes. La liste des connecteurs actifs et de leurs flux est consignée dans le dossier à l'installation.

Architecture

Trois briques sur une seule machine : les connecteurs vers vos outils, le moteur d'IA, et l'interface de validation.

- Connecteurs : ils lisent vos sources (messagerie, dossiers, logiciel comptable) et y réécrivent les résultats validés.
- Moteur : des modèles d'IA ouverts (familles Llama et Qwen), exécutés localement sur la machine par Ollama, avec une reconnaissance de texte locale (Tesseract) et un lecteur de factures QR ; les noms et versions exacts sont consignés dans le dossier à l'installation.
- Interface : une page web accessible depuis votre réseau interne seulement, où vos équipes valident ou corrigent.
- Aucune de ces briques n'est joignable depuis l'extérieur de votre réseau sans votre autorisation explicite.

PAGE 3

Mesures de sécurité

Chiffrement

Chiffrement du disque au repos et des échanges en transit sur votre réseau.

- Au repos : le disque de la machine est chiffré ; la méthode et la garde de la clé sont consignées dans le dossier à l'installation.
- En transit : les échanges entre vos postes et l'interface, et entre la machine et vos outils, passent par des connexions chiffrées (TLS), avec des certificats émis pour votre réseau et consignés dans le dossier.
- Les sauvegardes, si vous en demandez, sont chiffrées avant d'être écrites sur votre support.

Contrôle des accès et journalisation

Vous décidez qui accède au système ; chaque action est journalisée chez vous.

- Les comptes utilisateurs sont créés et retirés par vous ; l'intégration à votre annuaire existant est étudiée à l'installation.
- Les droits suivent les rôles : qui peut lancer un traitement, qui peut valider, qui peut consulter les journaux.
- Chaque traitement est journalisé : utilisateur, document, heure, résultat. Les journaux restent sur la machine ; leur durée de conservation est fixée avec vous.
- L'accès à distance de LX Studio pour le support passe par un tunnel chiffré que vous autorisez à l'installation et que vous pouvez couper à tout moment ; chaque intervention est datée et journalisée comme les autres.

Sauvegardes

Les sauvegardes sont faites sur vos supports, selon votre politique.

- Le système n'envoie aucune sauvegarde hors de votre réseau.
- Une sauvegarde planifiée tourne sur la machine ; vous choisissez le support (NAS, serveur, disque) et la fréquence. La procédure de restauration est décrite dans le dossier remis à l'installation.
- Les données traitées peuvent être purgées de la machine après validation, selon la durée que vous fixez.

Mises à jour

Planifiées avec vous, appliquées sur place ou par un accès que vous ouvrez le temps de l'intervention.

- Aucune mise à jour automatique silencieuse : chaque mise à jour est annoncée, datée et documentée.
- Les mises à jour de sécurité du système d'exploitation suivent votre politique interne : qui les applique, et quand, est fixé avec vous à l'installation.
- Les modèles d'IA ne changent pas sans un test sur vos vrais documents et votre accord.

En fin de contrat

PAGE 4

Conformité et engagements

nLPD et secret professionnel

Conçu pour respecter la nLPD : les données ne quittent pas vos murs et ne sont transmises à aucun tiers.

- La loi fédérale sur la protection des données (nLPD), en vigueur depuis le 1er septembre 2023, encadre le traitement des données personnelles par les entreprises suisses. Le système est conçu pour la respecter : traitement sur place, aucune communication à un tiers, journalisation, mesures de sécurité adaptées au risque (art. 8 LPD). Il ne s'agit pas d'une certification.
- Le secret professionnel (article 321 du Code pénal suisse) s'impose notamment aux avocats, aux notaires, aux médecins et aux autres professions de la santé, ainsi qu'aux réviseurs astreints au secret par le code des obligations ; les fiduciaires sont tenues par leur mandat et, souvent, par les règles de leur association. Les administrations relèvent du secret de fonction (article 320). Un traitement qui ne fait sortir aucun document de vos murs est la condition de base pour l'envisager. L'appréciation finale revient à votre conseil.
- Le Cloud Act américain, en vigueur depuis 2018, permet aux autorités des États-Unis de requérir les données qu'un fournisseur soumis à leur droit contrôle, où qu'elles soient hébergées. Un document traité sur votre machine n'est sous le contrôle d'aucun fournisseur : la question ne se pose pas.
- Un registre des traitements et une analyse d'impact peuvent être documentés avec vous si votre activité l'exige.

Source : Loi fédérale sur la protection des données (LPD, RS 235.1) et Code pénal (RS 311.0, art. 320 et 321), textes consolidés sur fedlex.admin.ch ; Préposé fédéral à la protection des données et à la transparence (PFPDT), https://www.fedlex.admin.ch/eli/cc/2022/491/fr

Engagements contractuels

- Aucune donnée traitée ne quitte le réseau du client pendant le traitement.
- Aucun accès à distance de LX Studio sans l'autorisation du client, qui peut le couper à tout moment ; chaque intervention est datée et journalisée.
- La machine, le code et la documentation restent au client en fin de contrat.
- Chaque mise à jour est annoncée, datée et documentée.

Contact

Tanguy Lachat, LX Studio
Rue des Romains 25, 2854 Bassecourt
contact@lxstudio.ch · 078 703 88 00
https://lxstudio.ch/securite